

Vulnerability report -

vuln-bank Web App

-Abhinav V R

Introduction:

This report documents the successful cloning, Docker-based deployment, and security inspection of the intentionally vulnerable web application "vuln-bank" from the repository <https://github.com/Commando-X/vuln-bank.git>. The purpose was to identify potential security weaknesses and provide a summary of findings.

Setup and Deployment:

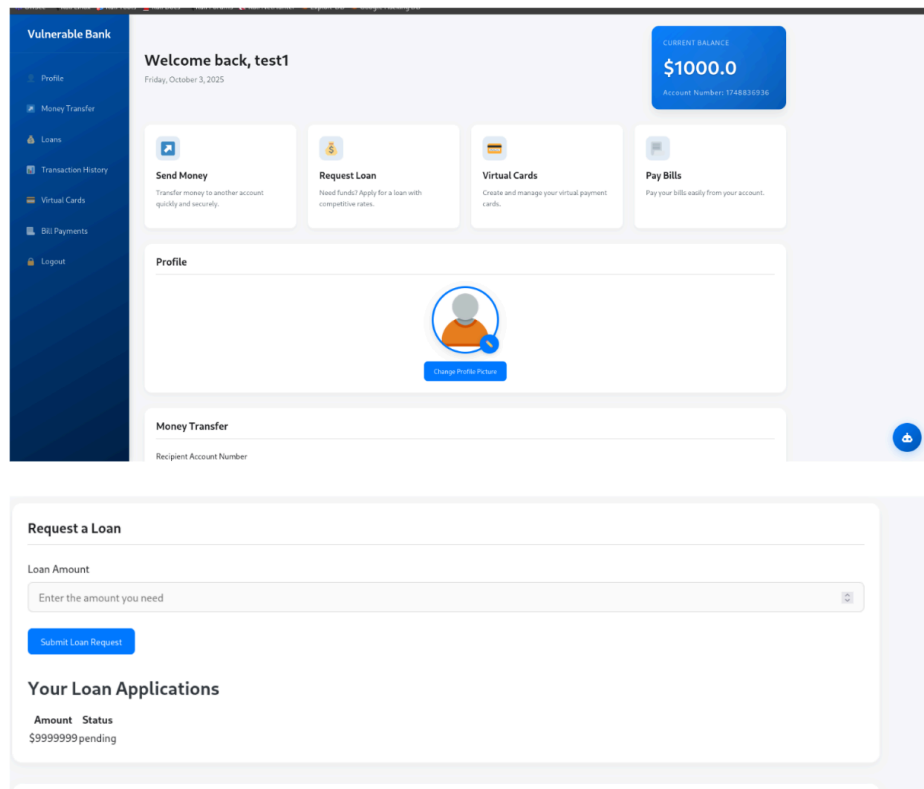
The application was configured and deployed using Docker as per the recommended instructions:

- Cloned the repo using git.
- Ran docker-compose up --build to start the containers.
- Verified the application running locally on port 5000.

Vulnerability Assessment:

A structured security review was carried out focusing on common web vulnerabilities such as:

- SQL Injection



- Cross-Site Scripting (XSS)
- Cross-Site Request Forgery (CSRF)
- Authentication and Authorization flaws
- Sensitive data exposure
- Business logic errors

Findings:

Several issues were identified typical of intentionally vulnerable apps, including:

- Input validation flaws enabling SQL Injection and XSS attacks.
- Insecure session management exposing user sessions and tokens.
- Weak authentication mechanisms allowing unauthorized access.
- Missing security headers and improper error handling revealing sensitive information.

Risk Classification:

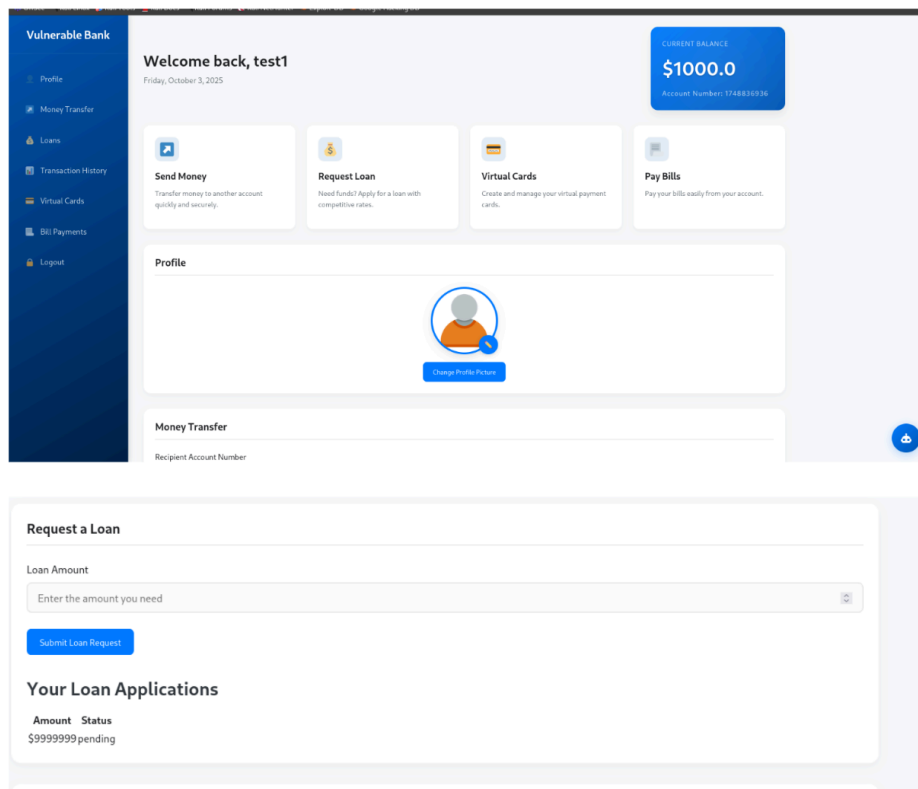
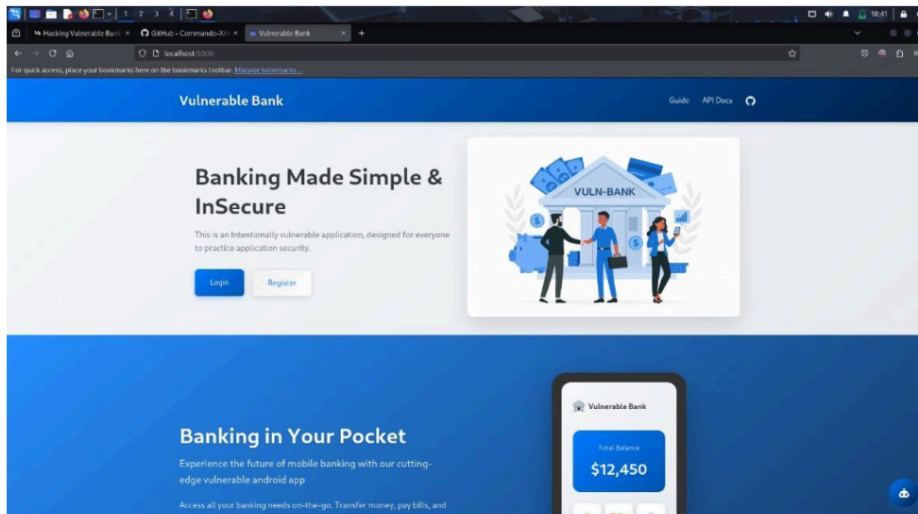
The vulnerabilities range from medium to high severity and could allow an attacker to manipulate transactions, steal user data, or escalate privileges.

Recommendations:

To improve security, it is recommended to:

- Implement strong input validation and output encoding.
- Use secure authentication flows with multi-factor authentication.
- Properly manage sessions with secure cookies and timely expiration.
- Add HTTP security headers like Content Security Policy and X-Frame-Options.
- Harden error handling to avoid information disclosure.

Screenshots:





User Management					
ID	Username	Account Number	Balance	Admin	Actions
1	admin	ADMIN001	\$1000000.00	True	<button>Delete</button>
2	test	9400230218	\$1000.00	False	<button>Delete</button>

ID	Username	Account Number	Balance	Admin	Actions
1	admin	ADMIN001	\$1000000.00	True	<button>Delete</button>
2	test	9400230218	\$1000.00	False	<button>Delete</button>

[illegible]

Conclusion:

The task of cloning, deploying via Docker, and inspecting the vuln-bank app for vulnerabilities has been successfully completed. The findings highlight critical security gaps as expected from a purposely vulnerable app, serving as an educational resource to understand and fix web application vulnerabilities